

SecureGuard Mobile — FastAPI Backend Integration Specification

1. Executive Summary

This document specifies the exact REST API architecture, HTTP communication contracts, data schemas, authentication flows, error handling matrices, and runtime mode behaviors implemented in **SecureGuard Mobile**.

The mobile client is built on a clean dual-execution model:

- **Demo / Simulation Mode** (`AppConfig.isDemoMode = true`): The mobile app runs completely standalone without requiring a live FastAPI backend. Full interactive navigation, threat triage, vulnerability charts, and AI security copilot responses are generated locally using clearly marked mock domain models. No false "Connected" statuses are reported.
- **Live FastAPI Backend Mode** (`AppConfig.isDemoMode = false`): The mobile app communicates directly over HTTP/HTTPS with the official SecureGuard FastAPI backend engine. All telemetry, authentication tokens, repository scans, and incident alerts are fetched and updated via real REST requests with full status code handling, network failure recovery, and zero secret leakage.

2. Network & Host Configuration

Environment	Base URL	Target Platform	Description
Android Emulator (Dev)	<code>http://10.0.2.2:8000</code>	Google Pixel 7 Emulator (AVD)	Direct loopback routing from Android QEMU virtual router to Windows host port <code>8000</code> .
Localhost / Desktop (Dev)	<code>http://127.0.0.1:8000</code>	Windows / macOS / Web / iOS Sim	Direct loopback to host port <code>8000</code> .
Production Cloud (Prod)	<code>https://api.secureguard.enterprise</code>	Production Devices (Release APK/AAB)	Enterprise TLS 1.3 secured gateway with certificate pinning.

Configurable Client Options

- **Connection Timeout:** `12 seconds`
- **Receive Timeout:** `12 seconds`
- **Send Timeout:** `12 seconds`
- **Health Probe Timeout:** `4 seconds`
- **Custom URL Switching:** Dynamically configurable in the in-app **Settings Screen** (`SettingsScreen`) with instant persistence to secure keystore storage.

3. Global HTTP Headers & Security Standards

Every outgoing request from `ApiClient` automatically attaches the following headers:

```
Content-Type: application/json
Accept: application/json
X-Client-Platform: Mobile-Flutter
Authorization: Bearer <JWT_ACCESS_TOKEN> (when user is authenticated)
```

Security & Sanitization Protocol

- **Credential Masking:** The logging interceptor automatically sanitizes sensitive fields (`password` , `token` , `authorization` , `secret` , `key` , `apiKey` , `access_token` , `refresh_token`) before printing to debug logs.
 - **Secure Token Storage:** JWT session tokens are persisted exclusively via `flutter_secure_storage` utilizing Android Keystore Hardware Security Module (HSM) encryption.
 - **No Hardcoded Secrets:** Secrets and tokens are never embedded into mobile assets or client binaries.
-

4. API Endpoints Specification

4.1. Health Check & Connectivity Probe

- **Endpoint:** `GET /health`
- **Authentication:** None (Public)
- **Headers:** `Accept: application/json` , `X-Client-Platform: Mobile-Flutter-Ping`
- **Request Body:** None
- **Flutter Screens:**
- `lib/features/settings/presentation/settings_screen.dart` (Test Ping & Live Connectivity Monitor)
- **Expected Response (200 OK):**

```
{
  "status": "healthy",
  "version": "1.0.0",
  "services": {
    "database": "connected",
    "wazuh_siem": "online",
    "semgrep_engine": "online"
  }
}
```

- **Error Handling:**

- Connection Refused: Reports `DISCONNECTED` / `Connection refused (port 8000 not listening)`.
 - Timeout: Reports `Connection Timeout (12s)`.
 - Non-200: Reports exact HTTP status code with latency measurement.
-

4.2. User Authentication (Login)

- **Endpoint:** `POST /v1/auth/login`
- **Authentication:** None (Public)
- **Headers:** `Content-Type: application/json`
- **Flutter Screens:**
- `lib/features/auth/presentation/login_screen.dart`
- `lib/features/auth/data/auth_repository.dart`
- **Request Body:**

```
{
  "email": "analyst@secureguard.enterprise",
  "password": "EnterprisePass123!"
}
```

- **Expected Response (200 OK / 201 Created):**

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "user": {
    "id": "usr_sec_01",
    "email": "analyst@secureguard.enterprise",
    "name": "Alex Vance",
    "role": "Principal Security Analyst",
    "organization": "Global Cybersecurity Ops",
    "mfa_enabled": true,
    "avatar_url": null
  }
}
```

- **Error Handling:**

- `401 Unauthorized` : Displays "Invalid credentials or unauthorized account".
- `400 Bad Request` : Displays validation error message.
- `Connection Refused / Network Error` : Displays network offline alert with option to switch to Demo Mode.

4.3. User Profile & Token Verification

- **Endpoint:** `GET /v1/auth/me`
- **Authentication:** Required (`Authorization: Bearer`)
- **Headers:** `Accept: application/json`
- **Flutter Screens:**
- `lib/features/profile/profile_screen.dart`
- `lib/features/splash/splash_screen.dart` (Session restoration)
- **Expected Response (200 OK):**

```
{
  "id": "usr_sec_01",
  "email": "analyst@secureguard.enterprise",
  "name": "Alex Vance",
  "role": "Principal Security Analyst",
  "organization": "Global Cybersecurity Ops",
  "mfa_enabled": true,
  "avatar_url": null
}
```

- **Error Handling:**
 - `401 Unauthorized` : Clears stored JWT token and prompts user to re-authenticate.
-

4.4. Executive Dashboard Telemetry

- **Endpoint:** `GET /v1/dashboard/summary`
- **Authentication:** Required (`Authorization: Bearer`)
- **Headers:** `Accept: application/json`
- **Flutter Screens:**
- `lib/features/dashboard/presentation/dashboard_screen.dart`
- `lib/features/dashboard/data/dashboard_repository.dart`
- **Request Body:** None
- **Expected Response (200 OK):**

```

{
  "posture_score": 88,
  "posture_status": "Secure",
  "total_repositories": 28,
  "total_scans_today": 142,
  "critical_count": 3,
  "high_count": 12,
  "medium_count": 24,
  "low_count": 58,
  "active_alerts_count": 7,
  "system_statuses": [
    {
      "name": "FastAPI Backend Engine",
      "status": "operational",
      "latency_ms": 18
    },
    {
      "name": "Wazuh SOC Connector",
      "status": "operational",
      "latency_ms": 22
    }
  ],
  "recent_events": [
    {
      "id": "evt_001",
      "title": "Wazuh: Multiple SSH authentication failures detected from external IP",
      "source": "Wazuh SOC",
      "severity": "Critical",
      "timestamp": "2026-08-22T20:15:00Z"
    }
  ],
  "recent_scans": [
    {
      "id": "scn_101",
      "target": "secureguard-backend (main)",
      "scan_type": "Semgrep SAST",
      "status": "Passed",
      "findings_count": 0,
      "duration": "18s",
      "timestamp": "2026-08-22T20:20:00Z"
    }
  ]
}

```

- **Error Handling:**

- If unreachable or server error in API Mode: `DashboardScreen` displays `SGErrorView` with retry button. In Demo Mode: loads offline telemetry immediately.

4.5. Monitored Code Repositories

- **Endpoint:** GET /v1/repositories
- **Authentication:** Required (Authorization: Bearer)
- **Headers:** Accept: application/json
- **Flutter Screens:**
 - lib/features/repositories/presentation/repositories_screen.dart
 - lib/features/repositories/presentation/repository_detail_screen.dart
 - lib/features/repositories/data/repository_repository.dart
- **Request Body:** None
- **Expected Response (200 OK):**

```
[
  {
    "id": "repo_01",
    "name": "secureguard-backend",
    "owner": "enterprise-security-org",
    "primary_language": "Python",
    "branch": "main",
    "is_private": true,
    "security_status": "Secure",
    "critical_count": 0,
    "high_count": 1,
    "medium_count": 3,
    "low_count": 5,
    "secret_findings": 0,
    "sast_findings": 4,
    "security_health_score": "A",
    "last_scanned_at": "2026-08-22T20:00:00Z"
  }
]
```

4.6. SOC & SIEM Incident Alerts

- **Endpoint:** GET /v1/soc/alerts
- **Authentication:** Required (Authorization: Bearer)
- **Headers:** Accept: application/json

- **Flutter Screens:**

- `lib/features/alerts/presentation/alerts_screen.dart`
- `lib/features/alerts/presentation/alert_detail_screen.dart`
- `lib/features/alerts/data/alerts_repository.dart`

- **Request Body:** None

- **Expected Response (200 OK):**

```
[
  {
    "id": "alt_001",
    "severity": "critical",
    "title": "Wazuh: Multiple SSH Brute Force Attacks Detected",
    "description": "Endpoint 192.168.1.105 experienced 48 failed SSH root login attempts with",
    "timestamp": "2026-08-22T20:25:00Z",
    "source": "Wazuh SOC",
    "status": "active",
    "remediation_recommendation": "Block source IP on edge firewall and enforce public key c"
  }
]
```

4.7. AI Security Copilot Chat & Remediation

- **Endpoint:** `POST /v1/ai/chat`
- **Authentication:** Required (`Authorization: Bearer`)
- **Headers:** `Content-Type: application/json`
- **Flutter Screens:**
- `lib/features/ai/presentation/ai_assistant_screen.dart`
- `lib/features/ai/data/ai_repository.dart`
- **Request Body:**

```
{
  "prompt": "How do I fix CVE-2024-3094 in my Dockerfile?",
  "context": "mobile_security_copilot"
}
```

- **Expected Response (200 OK):**

```
{
  "id": "msg_9012",
  "role": "assistant",
  "content": "### 🛡️ Remediation Plan: CVE-2024-3094 (XZ Utils Backdoor)\n\n1. Downgrade co
  "timestamp": "2026-08-22T20:30:00Z",
  "has_code": true,
  "code_snippet": "RUN apt-get install -y --allow-downgrades xz-utils=5.4.6"
}
```

4.8. Security Scans & CI/CD Telemetry

- **Endpoint:** GET /v1/scans
- **Authentication:** Required (Authorization: Bearer)
- **Headers:** Accept: application/json
- **Flutter Screens:**
 - lib/features/scans/scans_screen.dart
 - lib/features/scans/scan_detail_screen.dart
- **Expected Response (200 OK):**

```
[
  {
    "id": "scan_101",
    "target_name": "auth-gateway-service (main)",
    "type": "sast",
    "status": "completed",
    "findings_count": 8,
    "started_at": "2026-08-22T19:30:00Z",
    "completed_at": "2026-08-22T19:48:00Z",
    "trigger_by": "GitHub Actions workflow #4102"
  }
]
```

4.9. Vulnerability Findings Database

- **Endpoint:** GET /v1/findings
- **Authentication:** Required (Authorization: Bearer)
- **Headers:** Accept: application/json
- **Flutter Screens:**
 - lib/features/findings/findings_screen.dart
 - lib/features/findings/finding_detail_screen.dart
- **Expected Response (200 OK):**

```
[
  {
    "id": "fnd_001",
    "cve_id": "CVE-2024-3094",
    "title": "XZ Utils Backdoor Vulnerability in SSHD Pipeline",
    "description": "Malicious code introduced in XZ Utils versions 5.6.0 and 5.6.1 allows ur",
    "severity": "critical",
    "cvss_score": 10.0,
    "repository_name": "auth-gateway-service",
    "file_path": "infra/docker/base-image.Dockerfile",
    "line_number": 14,
    "remediation_guide": "Upgrade xz-utils package to version >= 5.6.2 immediately.",
    "is_resolved": false,
    "detected_at": "2026-08-22T17:30:00Z"
  }
]
```

5. Error Classification & Status Code Matrix

Status Code	Error Classification	Mobile App Action & Presentation
400	Bad Request	Displays validation error message returned by backend.
401	Unauthorized	Discards invalid session token, redirects to Login screen with notification.
403	Forbidden	Informs user of insufficient RBAC privileges for the requested resource.
404	Not Found	Shows clean not found message without crashing.
408	Request Timeout	Informs user that the backend server took too long to respond.
429	Rate Limited	Displays security gateway rate limit alert.
500	Internal Server Error	Displays graceful server error notice with retry action.
502 / 503 / 504	Gateway / Service Unavailable	Informs user that the FastAPI microservice is offline or undergoing maintenance.
Connection Refused	Host Offline	Displays DISCONNECTED / OFFLINE status. Never displays false "Connected".
Connection Timeout	Network Slow / Down	Cancels request after 12s timeout and presents retry button.

6. How to Connect the Live Real FastAPI Backend

When the real SecureGuard FastAPI backend repository is available or running:

- Start the FastAPI server on host:

```
bash
```

```
uvicorn main:app --host 0.0.0.0 --port 8000 --reload
```

```
`
```

- Open **SecureGuard Mobile** in the Android Emulator (**emulator-5554**).
- Navigate to **Settings** (5th tab).

- Verify target URL is set to `http://10.0.2.2:8000` .
- Tap **Test Ping** — the app will perform an immediate live HTTP health check and display the response latency and online status.
- Toggle **Offline / Demo Simulation Mode** off to switch the entire application into Live FastAPI API mode.